

CONTRALORÍA GENERAL DE LA NACIÓN
República de Colombia

INFORME DE PRUEBAS DE PENETRACIÓN (PENTEST)
Sistema de Auditoría Inteligente — SAI-CGN

IPT-SAI-CGN-001 | v1.0 | Fase de Pruebas — SAI-CGN

Campo	Detalle
Proyecto	Sistema de Auditoría Inteligente — SAI-CGN
Código del documento	IPT-SAI-CGN-001
Versión	1.0 — Informe Final (post-retest)
Fecha de ejecución	20 al 24 de octubre de 2025 (Pentest inicial)
Fecha del retest	3 al 5 de noviembre de 2025
Fecha del informe final	7 de noviembre de 2025
Empresa ejecutora	CiberSec Colombia S.A.S. — Empresa certificada OSCP/CEH
Metodología	OWASP Testing Guide v4.2 · OWASP Top 10 2021 · OWASP ASVS L2
Revisado por	Ramón Castellanos — Oficial de Seguridad CGN
Aprobado por	Laura Rodríguez — Subdirectora de Sistemas CGN
Marco normativo	Decreto 1008/2018 · ISO 27001 · NIST 800-63B
Clasificación	CONFIDENCIAL — Distribución restringida al equipo CGN y Proveedor

AVISO DE CONFIDENCIALIDAD: Este documento contiene información sensible sobre vulnerabilidades de seguridad del sistema SAI-CGN. Su distribución está estrictamente limitada al Oficial de Seguridad CGN, la Subdirectora de Sistemas, el Director de Control Fiscal y el Líder de Proyecto del proveedor. Está PROHIBIDA su reproducción, distribución o almacenamiento fuera de los sistemas institucionales de la CGN.

1. RESUMEN EJECUTIVO

CiberSec Colombia S.A.S. fue contratada para realizar las pruebas de penetración del Sistema de Auditoría Inteligente SAI-CGN, en cumplimiento del requisito RNF-11 de la ERS v1.0 y del Marco de Seguridad Digital del MINTIC (Decreto 1008/2018). Las pruebas se ejecutaron sobre el ambiente de staging de la CGN entre el 20 y el 24 de octubre de 2025.

El equipo identificó 14 hallazgos de seguridad en la evaluación inicial. Todos los hallazgos de severidad Crítica y Alta fueron remediados por el equipo de desarrollo y verificados mediante retest del 3 al 5 de noviembre de 2025. El informe final certifica que el sistema SAI-CGN no presenta vulnerabilidades de severidad Crítica ni Alta abiertas.

Severidad	Hallazgos iniciales	Remediados	Verificados en retest	Abiertos al cierre
Crítica	0	—	—	0
Alta	2	2	2	0
Media	7	5	5	2 (con plan de remediación)
Baja	5	2	2	3 (aceptados por riesgo residual)
TOTAL	14	9	9	5

DICTAMEN FINAL: El sistema SAI-CGN CUMPLE el requisito RNF-11 de la ERS v1.0. No existen vulnerabilidades de severidad Crítica ni Alta abiertas al momento de la emisión de este informe. El sistema está habilitado para desplegarse en producción desde la perspectiva de seguridad, sujeto al plan de remediación de las vulnerabilidades Medias pendientes.

2. ALCANCE Y METODOLOGÍA

2.1 Alcance del Pentest

Componente en alcance	Tipo de prueba	Descripción
Aplicación web (frontend React)	Caja gris	Pruebas de XSS, CSRF, clickjacking, inyección en formularios
APIs REST del backend (FastAPI)	Caja gris	Autenticación, autorización, inyección, exposición de datos
Módulo de autenticación SSO/LDAP	Caja gris	Fuerza bruta, bypass de autenticación, MFA
Módulo de carga de archivos (M02)	Caja negra	Carga de archivos maliciosos, path traversal, DoS
API del asistente RAG (M04)	Caja gris	Prompt injection, extracción de datos del corpus
Configuración de seguridad del servidor	Caja gris	TLS, cabeceras HTTP, exposición de información
Gestión de sesiones y tokens JWT	Caja gris	Expiración, invalidación, forjado de tokens
Logs de auditoría (M08)	Caja gris	Inmutabilidad, acceso no autorizado, bypass

2.2 Metodología aplicada

Fase	Actividades	Herramientas
1. Reconocimiento	Enumeración de endpoints, tecnologías, versiones de componentes, DNS, puertos.	Nmap · Shodan · Wappalyzer · Burp Suite
2. Análisis de vulnerabilidades	Escaneo automático de vulnerabilidades conocidas (CVE). Revisión de dependencias.	OWASP ZAP · Nikto · OWASP Dependency Check
3. Explotación	Intento de explotación manual de vulnerabilidades identificadas.	Burp Suite Pro · SQLMap · Metasploit (módulos web)
4. Post-explotación	Verificación del alcance real de cada vulnerabilidad explotada.	Manual
5. Reporte	Clasificación CVSS v3.1, evidencias, impacto y recomendaciones.	Manual
6. Retest	Verificación de remediaciones implementadas por el equipo de desarrollo.	Burp Suite Pro · Manual

3. HALLAZGOS DE SEGURIDAD

3.1 Hallazgos de severidad Alta (remediados)

PT-001 Ausencia de validación de tipo MIME en carga de archivos (M02)			Severidad: Alta		
CVSS v3.1	8.1 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N)	Categoría OWASP	A04:2021 — Insecure Design	Estado	Remediado — verificado en retest (05/Nov/2025)
Descripción: El endpoint de carga de archivos del módulo M02 validaba únicamente la extensión del archivo pero no el tipo MIME real del contenido. Un usuario autenticado con rol Analista de Datos podía cargar un archivo PHP renombrado como 'datos.csv' y potencialmente ejecutarlo en el servidor.					
Evidencia: Se cargó exitosamente el archivo 'test.php' renombrado como 'test_datos.csv'. El archivo fue almacenado en el servidor. No se logró la ejecución remota del código debido a la configuración del servidor web, pero el archivo malicioso quedó almacenado.					
Impacto: Almacenamiento de archivos maliciosos en el servidor. Riesgo potencial de ejecución de código remoto si la configuración del servidor cambia. Compromiso de la integridad de los datos del sistema.					
Remediación: Implementada validación del tipo MIME real del archivo (python-magic) antes de aceptar la carga. Implementada lista blanca estricta de tipos MIME permitidos: text/csv, application/vnd.ms-excel, application/json, text/xml. Archivos rechazados son registrados en el log de seguridad.					

PT-002 Tokens JWT sin lista de revocación (blacklist) al cerrar sesión			Severidad: Alta		
CVSS v3.1	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)	Categoría OWASP	A07:2021 — Identification and Authentication Failures	Estado	Remediado — verificado en retest (04/Nov/2025)
Descripción: Al cerrar sesión, el token JWT del usuario no era invalidado en el servidor. Un atacante que hubiera obtenido el token (por sniffing o robo del dispositivo) podía seguir usándolo hasta su expiración natural (configurada en 8 horas), mucho tiempo después de que el usuario cerrara sesión.					
Evidencia: Se capturó el token JWT de una sesión activa. El usuario cerró sesión manualmente. Con el token capturado se realizaron llamadas exitosas a la API durante 4 horas adicionales al cierre de sesión.					
Impacto: Acceso no autorizado al sistema con tokens robados durante hasta 8 horas después del cierre de sesión. Riesgo crítico dado que el sistema maneja información fiscal confidencial y hallazgos de posibles hechos punibles.					
Remediación: Implementada lista de revocación de tokens (Redis blacklist) con TTL igual al tiempo de expiración del JWT. Al cerrar sesión, el token es agregado inmediatamente a la blacklist. Todas las requests verifican contra la blacklist antes					

de procesar. Tiempo de expiración reducido a 30 minutos con renovación silenciosa.

3.2 Hallazgos de severidad Media

ID	Título	CVSS	Categoría OWASP	Estado
PT-003	Cabeceras de seguridad HTTP incompletas (CSP, HSTS, X-Frame-Options)	5.3	A05:2021 — Security Misconfiguration	Remediado
PT-004	Enumeración de usuarios mediante mensajes de error diferenciados en el login	5.3	A07:2021 — Auth Failures	Remediado
PT-005	Dependencias de terceros con vulnerabilidades conocidas (3 CVEs Medios)	5.1	A06:2021 — Vulnerable Components	Remediado
PT-006	Logs de auditoría accesibles desde la interfaz web sin paginación adecuada (DoS potencial)	4.3	A04:2021 — Insecure Design	Remediado
PT-007	Rate limiting insuficiente en el endpoint del asistente RAG (> 100 req/min por usuario)	4.3	A04:2021 — Insecure Design	Remediado
PT-008	Prompt injection parcial en el asistente RAG — respuestas fuera de dominio posibles	4.0	A03:2021 — Injection	Abierto — plan de remediación activo
PT-009	Información de versión del servidor expuesta en cabeceras HTTP	3.7	A05:2021 — Security Misconfiguration	Abierto — plan de remediación activo

3.3 Hallazgos de severidad Baja (riesgo residual aceptado)

ID	Título	CVSS	Justificación de aceptación
PT-010	Cookies de sesión sin atributo 'SameSite=Strict'	3.1	El sistema solo opera en red interna CGN. El riesgo real de CSRF es muy bajo en este contexto.
PT-011	Ausencia de CAPTCHA en el formulario de login (solo SSO)	2.9	El sistema usa SSO con LDAP; el formulario de login es solo un redirect. Bloqueo por intentos fallidos (RF-04) mitiga el riesgo.
PT-012	Mensajes de error verbosos en ambiente de desarrollo (no en producción)	2.3	Solo ocurre con la variable DEBUG=True. En producción siempre está en False. Se confirma la configuración.
PT-013	Timeout de sesión configurable por el administrador sin límite mínimo	2.1	El administrador puede reducir el timeout a 0; se restringió el mínimo a 5 minutos vía validación de backend.

ID	Título	CVSS	Justificación de aceptación
PT-014	Ausencia de verificación de integridad en archivos de configuración	2.0	Solo accesible por el administrador del sistema. Control compensatorio: acceso físico al servidor requiere autenticación biométrica.

4. PLAN DE REMEDIACIÓN DE HALLAZGOS PENDIENTES

ID	Hallazgo	Responsable	Fecha límite	Medida compensatoria temporal
PT-008	Prompt injection parcial en asistente RAG	Sebastián Ríos — Científico de Datos	30 Nov 2025	Filtro de salida implementado que detecta y bloquea respuestas fuera del dominio fiscal. Monitoreo manual semanal de conversaciones.
PT-009	Versión del servidor en cabeceras HTTP	Carolina Vega — Dev Backend	20 Nov 2025	Sin medida compensatoria requerida; impacto muy bajo. La información expuesta no es explotable directamente.

5. RESULTADOS DEL RETEST

El retest fue ejecutado por CiberSec Colombia S.A.S. del 3 al 5 de noviembre de 2025, verificando exclusivamente los 9 hallazgos que el equipo de desarrollo reportó como remediados.

ID	Hallazgo	Resultado del retest	Fecha verificación
PT-001	Validación tipo MIME en carga de archivos	REMEDIADO — Verificado	04/Nov/2025
PT-002	Tokens JWT sin lista de revocación	REMEDIADO — Verificado	03/Nov/2025
PT-003	Cabeceras de seguridad HTTP incompletas	REMEDIADO — Verificado	03/Nov/2025
PT-004	Enumeración de usuarios en login	REMEDIADO — Verificado	03/Nov/2025
PT-005	Dependencias con CVEs conocidos	REMEDIADO — Verificado	04/Nov/2025
PT-006	Logs sin paginación (DoS potencial)	REMEDIADO — Verificado	04/Nov/2025
PT-007	Rate limiting insuficiente en RAG	REMEDIADO — Verificado	05/Nov/2025
PT-013	Timeout de sesión sin límite mínimo	REMEDIADO — Verificado	05/Nov/2025
PT-014	Integridad de archivos de configuración	REMEDIADO — Verificado	05/Nov/2025

6. CONCLUSIÓN Y CERTIFICACIÓN

Con base en los hallazgos identificados, las remediaciones verificadas y el análisis del riesgo residual de los hallazgos pendientes, CiberSec Colombia S.A.S. emite la siguiente conclusión:

CERTIFICACIÓN DE SEGURIDAD: El sistema SAI-CGN, en su versión desplegada en el ambiente de staging de la Contraloría General de la Nación, NO presenta vulnerabilidades de severidad Crítica ni Alta abiertas al 7 de noviembre de 2025. Los hallazgos de severidad Media pendientes (PT-008 y PT-009) tienen planes de remediación activos con fechas definidas y medidas compensatorias temporales implementadas. El sistema cumple el requisito RNF-11 de la ERS v1.0 y las condiciones del Marco de Seguridad Digital del MINTIC (Decreto 1008/2018) para su despliegue en producción.

7. FIRMAS DE APROBACIÓN

Nombre y cargo	Rol	Firma	Fecha
Director Técnico — CiberSec Colombia S.A.S.	Firma del informe (empresa Pentest)	_____	__/__/__
Ramón Castellanos — Oficial de Seguridad CGN	Revisó y validó los resultados	_____	__/__/__
Laura Rodríguez — Subdirectora de Sistemas CGN	Aprobó institucionalmente	_____	__/__/__
Carlos Martínez — Director de Control Fiscal	Tomó conocimiento ejecutivo	_____	__/__/__